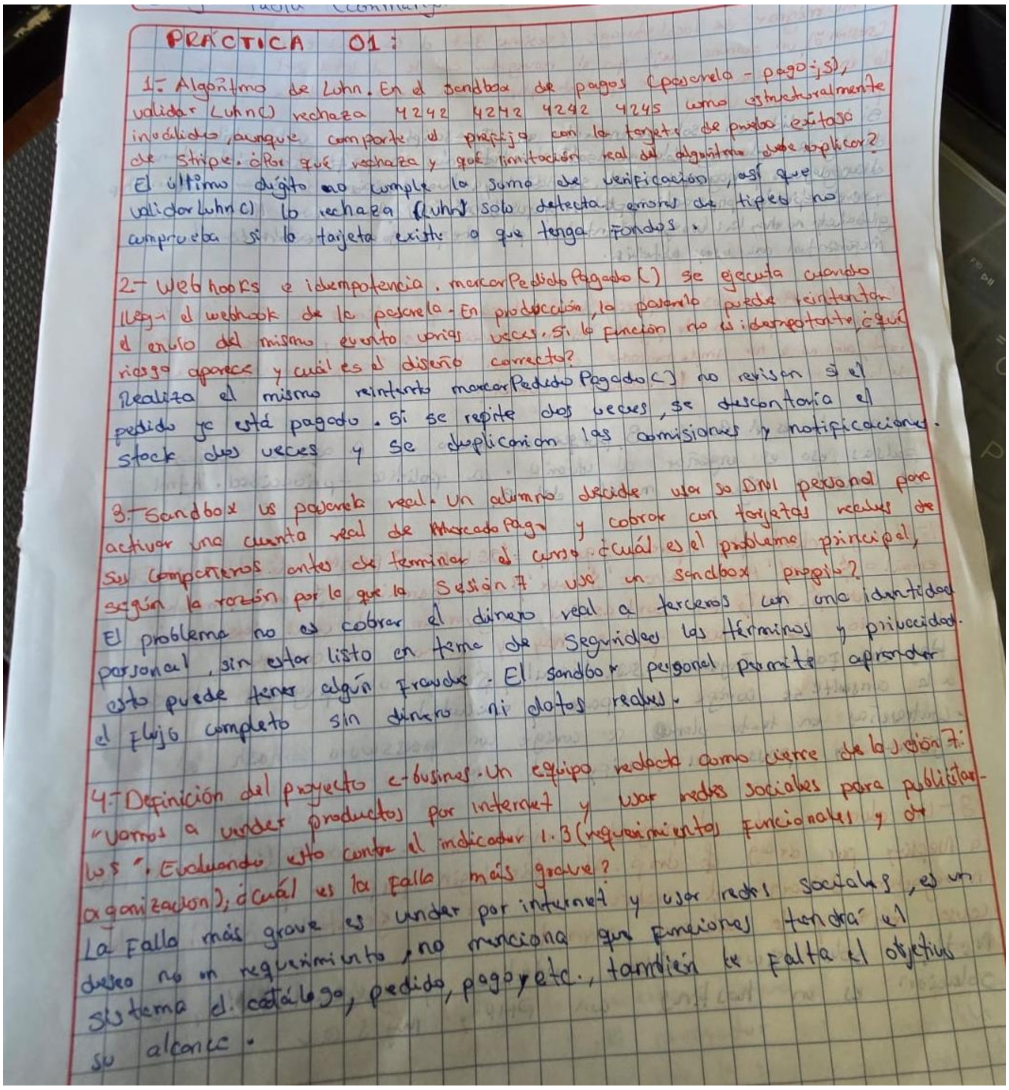


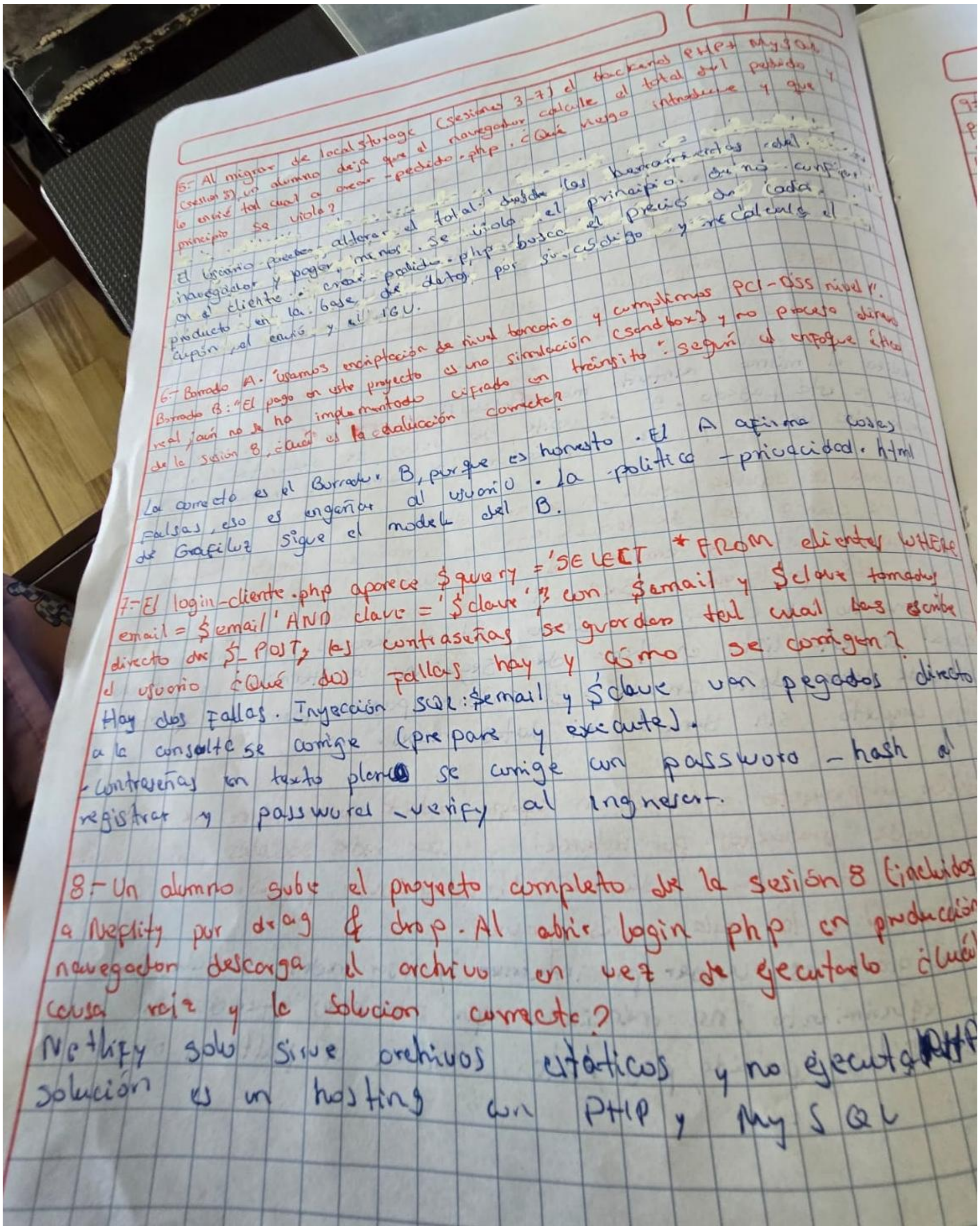
PRÁCTICA 01:

1.- Algoritmo de Luhn. En el sandbox de pagos (pasarela-pago.js), validarLuhn() rechaza 4242 4242 4242 4245 como estructuralmente inválido, aunque comparte el prefijo con la tarjeta de prueba exitosa de Stripe. ¿Por qué rechaza y qué limitación real del algoritmo debe explicar?
El último dígito no cumple la suma de verificación, así que validarLuhn() lo rechaza. (Luhn) solo detecta errores de tipeo, no comprueba si la tarjeta existe o que tenga fondos.

2.- Webhooks e idempotencia. marcarPedidoPagado() se ejecuta cuando llega el webhook de la pasarela. En producción, la pasarela puede reintentar el envío del mismo evento varias veces. Si la función no es idempotente, ¿qué riesgo aparece y cuál es el diseño correcto?
Realiza el mismo reintento marcarPedidoPagado() no revisan si el pedido ya está pagado. Si se repite dos veces, se descontaría el stock dos veces y se duplicarían las comisiones y notificaciones.

3.- Sandbox vs pasarela real. Un alumno decide usar su DNI personal para activar una cuenta real de MercadoPago y cobrar con tarjetas reales de sus compañeros antes de terminar el curso. ¿Cuál es el problema principal, según la razón por la que la Sesión 7 usa un sandbox propio?
El problema no es cobrar el dinero real a terceros con una identidad personal, sin estar listo en tema de seguridad, los términos y privacidad. Esto puede tener algún fraude. El sandbox personal permite aprender el flujo completo sin dinero ni datos reales.

4.- Definición del proyecto e-business. Un equipo redacta como cierre de la sesión 7: "Vamos a vender productos por internet y usar redes sociales para publicitarlos". Evaluando esto contra el indicador 1.3 (requerimientos funcionales y de organización); ¿cuál es la falla más grave?
La falla más grave es vender por internet y usar redes sociales, es un deseo no un requerimiento, no menciona qué funciones tendrá el sistema el catálogo, pedido, pago y etc., también le falta el objetivo su alcance.



5.- Al migrar de localStorage (sesiones 3-7) al backend PHP + MySQL (sesión 8), un alumno deja que el navegador calcule el total del pedido y lo envíe tal cual a crear-pedido.php. ¿Qué riesgo introduce y qué principio se violó?

El usuario puede alterar el total desde las herramientas del navegador y pagar menos. Se violó el principio de no confiar en el cliente. crear-pedido.php busca el precio de cada producto en la base de datos por su código y recalcula el cupón, el envío y el IGV.

6.- Borrado A: "usamos encriptación de nivel bancario y cumplimos PCI-DSS nivel 1". Borrado B: "El pago en este proyecto es una simulación (sandbox) y no proceso dinero real; aún no se ha implementado cifrado en tránsito". Según el enfoque ético de la sesión 8, ¿cuál es la evaluación correcta?

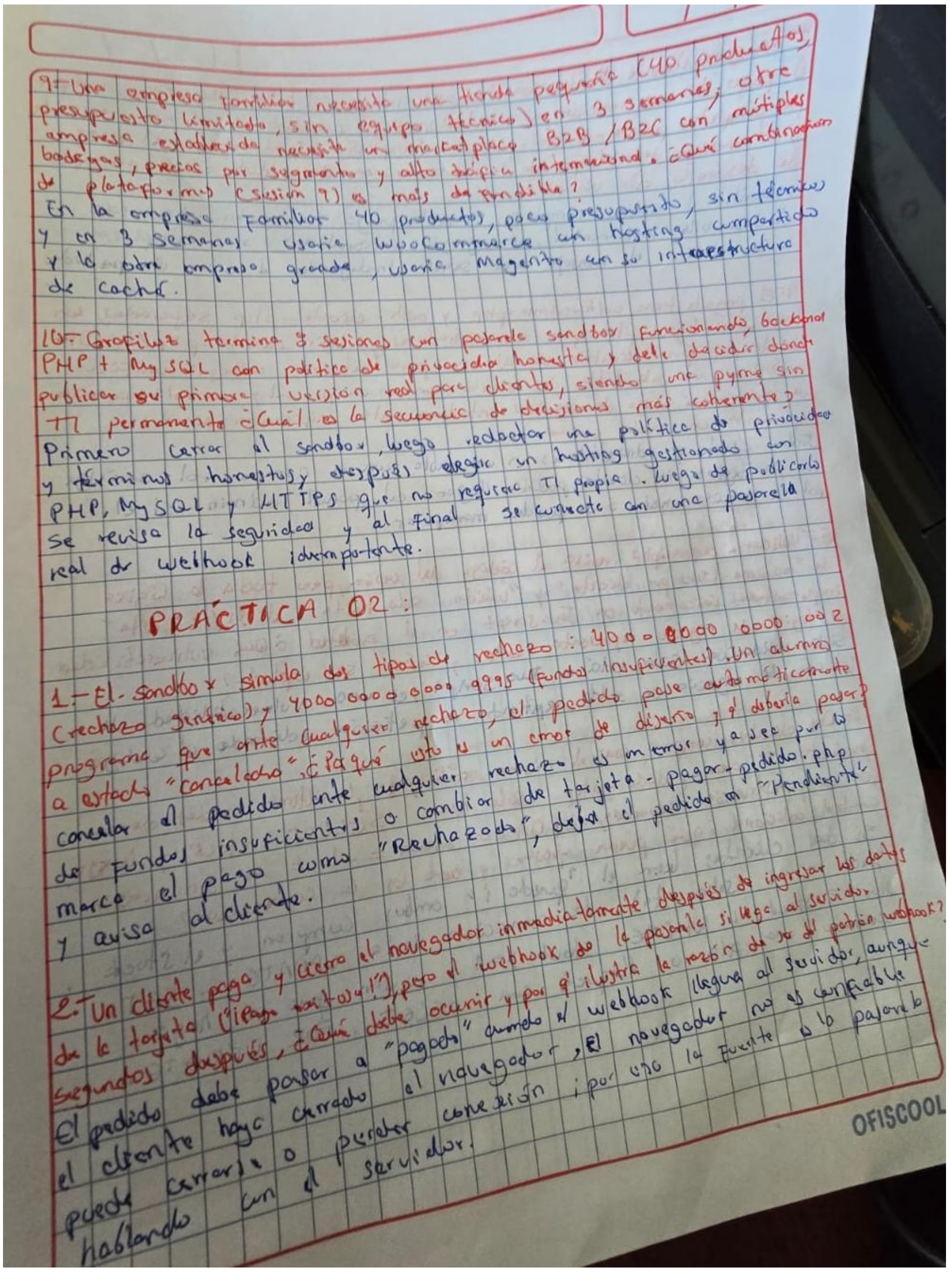
Lo correcto es el Borrador B, porque es honesto. El A afirma cosas falsas, eso es engañar al usuario. La politica-privacidad.html de Grafiluz sigue el modelo del B.

7.- El login-cliente.php aparece $query = 'SELECT * FROM clientes WHERE email = '$email' AND clave = '$clave''; con $email y $clave tomados directo de $_POST; las contraseñas se guardan tal cual las escribe el usuario. ¿Qué dos fallas hay y cómo se corrigen?

Hay dos fallas. Inyección SQL: $email y $clave van pegados directo a la consulta; se corrige (prepare y execute). Contraseñas en texto plano: se corrige con password_hash al registrar y password_verify al ingresar.

8.- Un alumno sube el proyecto completo de la sesión 8 (incluidos a Netlify por drag & drop. Al abrir login.php en producción navegador descarga el archivo en vez de ejecutarlo. ¿Cuál causa raíz y la solución correcta?

Netlify solo sirve archivos estáticos y no ejecuta PHP. solución es un hosting con PHP y MySQL



9.-Una empresa familiar necesita una tienda pequeña (40 productos, presupuesto limitado, sin equipo técnico) en 3 semanas; otra empresa establecida necesita un marketplace B2B / B2C con múltiples bodegas, precios por segmento y alto tráfico internacional. ¿Qué combinación de plataformas (sesión 9) es más defendible?

En la empresa familiar 40 productos, poco presupuesto, sin técnicos y en 3 semanas usaría WooCommerce con hosting compartido y la otra empresa grande, usaría Magento con su infraestructura de caché.

10.-Grafilbz terminó 3 sesiones con pasarela sandbox funcionando, backend PHP + MySQL con política de privacidad honesta y debe decidir dónde publicar su primera versión real para clientes, siendo una pyme sin TI permanente ¿Cuál es la secuencia de decisiones más coherente?

Primero cerrar el sandbox, luego redactar una política de privacidad y términos honestos, y después elegir un hosting gestionado con PHP, MySQL y HTTPS que no requiera TI propia. Luego de publicarlo se revisa la seguridad y al final se conecta con una pasarela real de webhook idempotente.

## PRÁCTICA 02:

1.-El sandbox simula dos tipos de rechazo: 4000 0000 0000 0002 (rechazo genérico) y 4000 0000 0000 9995 (fondos insuficientes). Un alumno programa que ante cualquier rechazo, el pedido pase automáticamente a estado "cancelado". ¿Por qué esto es un error de diseño y q' debería pasar?

Cancelar el pedido ante cualquier rechazo es un error ya sea por lo de fondos insuficientes o cambiar de tarjeta. pagar-pedido.php marca el pago como "Rechazado", deja el pedido en "Pendiente" y avisa al cliente.

2.-Un cliente paga y cierra el navegador inmediatamente después de ingresar los datos de la tarjeta ("¡Pago exitoso!"), pero el webhook de la pasarela sí llega al servidor segundos después, ¿Qué debe ocurrir y por q' ilustra la razón de ser del patrón webhook?

El pedido debe pasar a "pagado" cuando el webhook llegue al servidor, aunque el cliente haya cerrado el navegador, el navegador no es confiable puede cerrarse o perder conexión; por eso la fuente es la pasarela hablando con el servidor.

OFISCOOL

3- La guía Docente de la sesión 7 exige integrar el botón "Pagar" sin romper el flujo de confirmación por whatsApp ¿y ya funcionaba. Un alumno reescribe por completo puente-digital.js para "simplificarlo" al agregar el pago, y el mensaje de whatsApp deja de incluir el número de pedido ¿Qué principio de desarrollo está violando?

reescribir el código completo rompe lo que ya funcionaba. Se viola el desarrollo incremental, se agrega funcionalidad sin reemplazar lo que sirve y el mensaje debe seguir incluyendo el número de pedido.

4- El proyecto tiene auth-admin.php y auth-cliente.php separados, con login.php/logout.php para administradores y login-cliente.php/logout-cliente.php para clientes. Un alumno, para "ahorrar código" unifica ambos en una sola tabla de usuarios con un campo rol y una sola función de login. ¿Qué riesgo de seguridad introduce esta unificación si no se implementa con mucho cuidado?

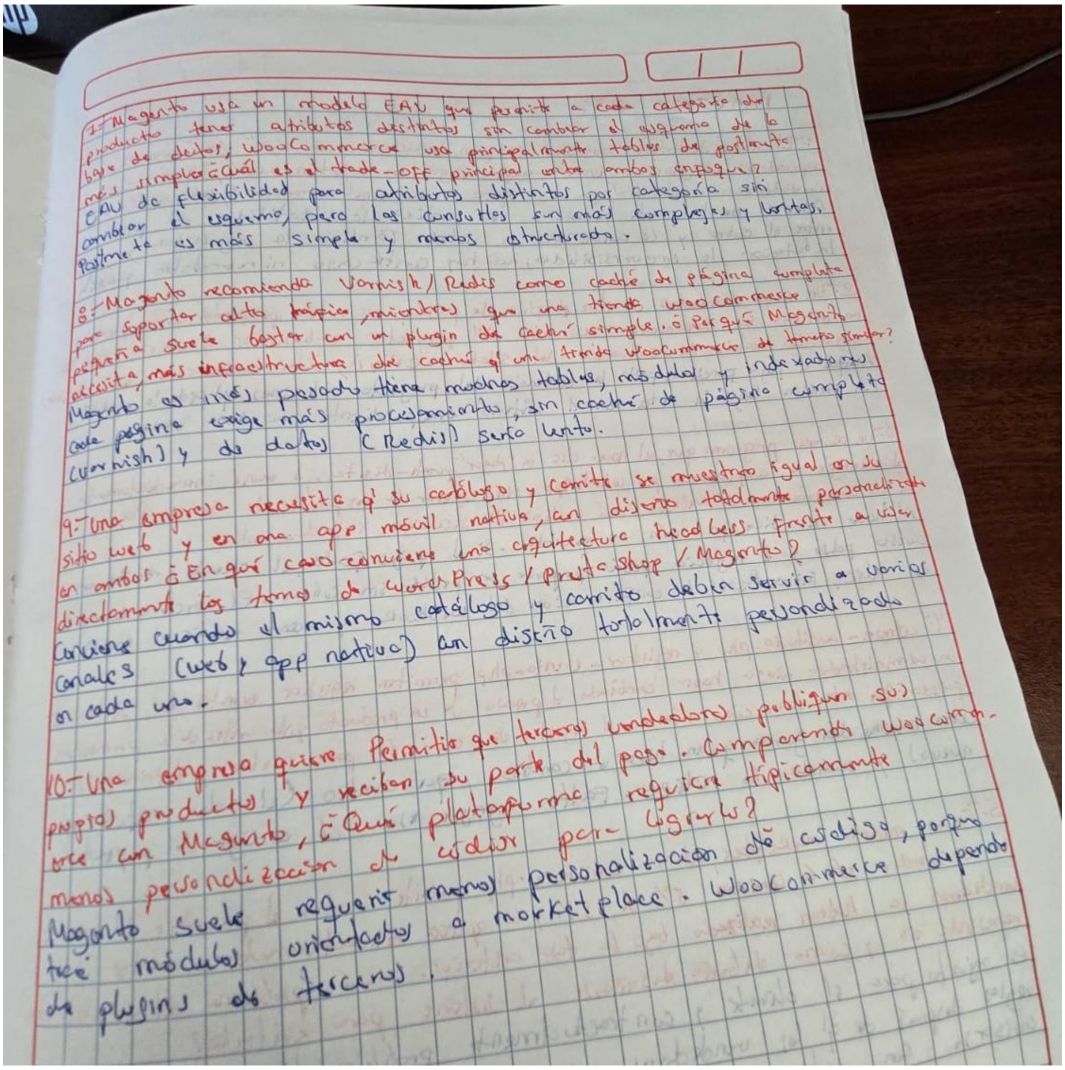
Juntar clientes y administradores en una tabla con un campo rol arriesga los privilegios. Un cliente podría llegar al panel admin si el rol se valida mal o se puede manipular.

5- Validar-cupon.php revisa el código del cupón, pero toda la lógica de "máximo 1 uso por cliente" y "válido solo hasta el 31/12" está implementada únicamente en Javascript en el Frontend. ¿Qué vulnerabilidad de lógica de negocio representa esto, y cómo se explota?

Si la validación solo está en Java Script, es una vulnerabilidad de lógica de negocio, se salta repitiendo la petición editando el código

6- Dos clientes compran, casi al mismo milisegundo, la última unidad de un producto. Si crear-pedido.php solo hace SELECT stock y luego, en una instrucción separada, UPDATE stock = stock -1 sin ningún control adicional ¿qué puede pasar y cuál es la corrección?

Si dos clientes leen el "quedo 1", ambos compran y el stock queda en -1 (sobreventa). La corrección sería UPDATE ... SET stock = stock -1 WHERE stock >= 1 y revisar que se haya afectado una pila o bloquear con SELECT... FOR UPDATE.



7.- Magento usa un modelo EAV que permite a cada categoría de producto tener atributos distintos sin cambiar el esquema de la base de datos; WooCommerce usa principalmente tablas de postmeta más simples. ¿Cuál es el trade-off principal entre ambos enfoques?

EAV da flexibilidad para atributos distintos por categoría sin cambiar el esquema, pero las consultas son más complejas y lentas. Postmeta es más simple y menos estructurado.

8.- Magento recomienda Varnish/Redis como caché de página completa para soportar alto tráfico, mientras que una tienda WooCommerce pequeña suele bastar con un plugin de caché simple. ¿Por qué Magento necesita más infraestructura de caché q' una tienda WooCommerce de tamaño similar?

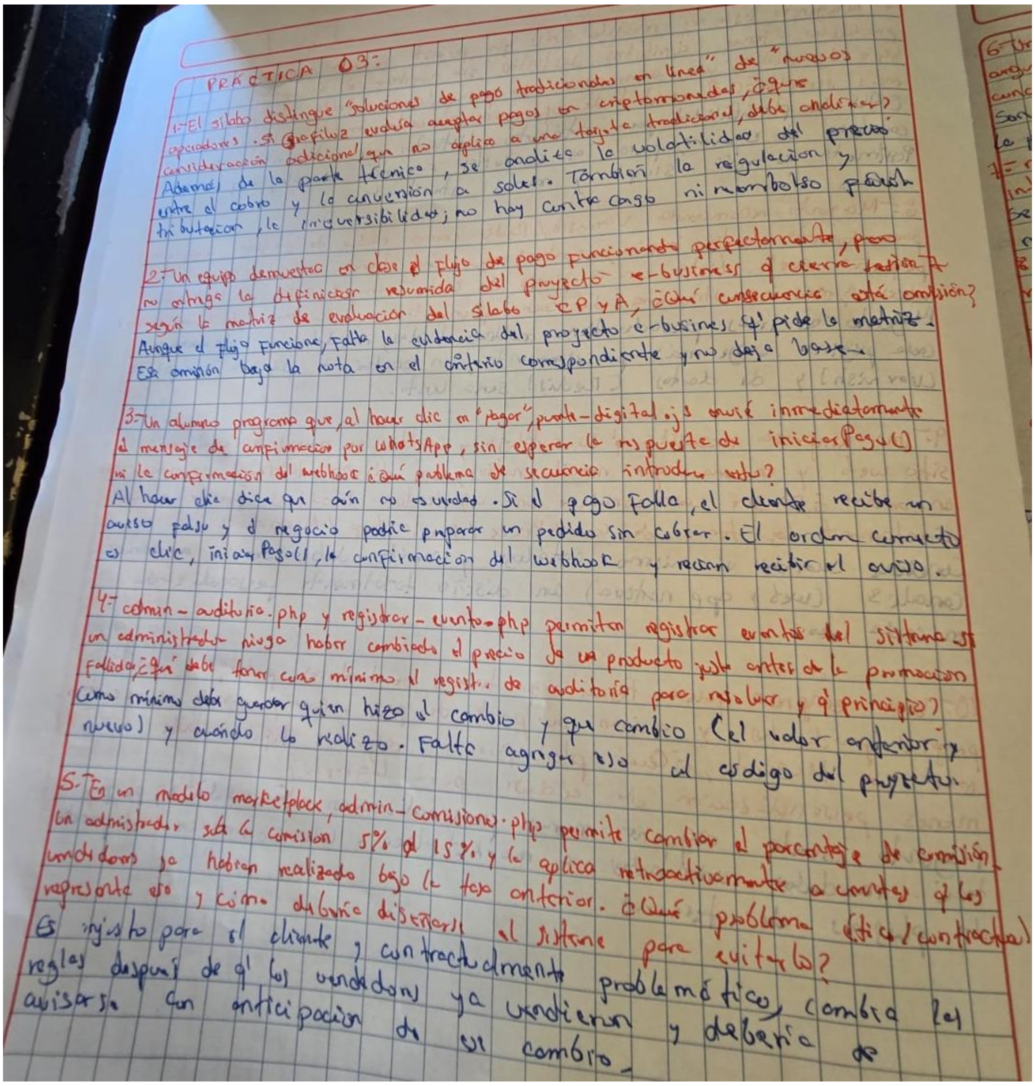
Magento es más pesado tiene muchas tablas, módulos y indexadores cada página exige más procesamiento, sin caché de página completa (Varnish) y de datos (Redis) sería lento.

9.- Una empresa necesita q' su catálogo y carrito se muestren igual en su sitio web y en una app móvil nativa, con diseño totalmente personalizado en ambos. ¿En qué caso conviene una arquitectura headless frente a usar directamente los temas de WordPress / PrestaShop / Magento?

Conviene cuando el mismo catálogo y carrito deben servir a varios canales (web y app nativa) con diseño totalmente personalizado en cada uno.

10.- Una empresa quiere permitir que terceros vendedores publiquen sus propios productos y reciban su parte del pago. Comparando WooCommerce con Magento, ¿Qué plataforma requiere típicamente menos personalización de código para lograrlo?

Magento suele requerir menos personalización de código, porque trae módulos orientados a marketplace. WooCommerce depende de plugins de terceros.



PRÁCTICA 03:

1.- El silabo distingue "soluciones de pago tradicionales en línea" de "nuevos operadores". Si Grafilux evalúa aceptar pagos en criptomonedas, ¿qué consideración adicional que no aplica a una tarjeta tradicional, debe analizar?

Además de la parte técnica, se analiza la volatilidad del precio entre el cobro y la conversión a soles. También la regulación y tributación, la irreversibilidad; no hay contracargo ni reembolso fácil.

2.- Un equipo demuestra en clase el flujo de pago funcionando perfectamente, pero no entrega la definición resumida del proyecto e-business q' cierra sesión 7 según la matriz de evaluación del silabo EP y A, ¿Qué consecuencia tiene esta omisión?

Aunque el flujo funcione, falta la evidencia del proyecto e-busines q' pide la matriz. Esa omisión baja la nota en el criterio correspondiente y no deja base.

3.- Un alumno programa que, al hacer clic en "pagar", punto-digital.js envíe inmediatamente el mensaje de confirmación por WhatsApp, sin esperar la respuesta de iniciarPago() ni la confirmación del webhook ¿Qué problema de secuencia introduce esto?

Al hacer clic dice que aún no es verdad. Si el pago falla, el cliente recibe un aviso falso y el negocio podría preparar un pedido sin cobrar. El orden correcto es clic, iniciarPago(), la confirmación del webhook y recién recibir el aviso.

4.- admin-auditoria.php y registrar-evento.php permiten registrar eventos del sistema. Si un administrador niega haber cambiado el precio de un producto justo antes de la promoción fallida, ¿qué debe tener como mínimo el registro de auditoría para resolver y q' principio?)

Como mínimo debe guardar quién hizo el cambio y qué cambió (el valor anterior y nuevo) y cuándo lo realizó. Falta agregar eso al código del proyecto.

5.- En un modelo marketplace, admin-comisiones.php permite cambiar el porcentaje de comisión. Un administrador sube la comisión 5% al 15% y la aplica retroactivamente a ventas q' los vendedores ya habían realizado bajo la tasa anterior. ¿Qué problema (ético/contractual) representa eso y cómo debería diseñarse el sistema para evitarlo?

Es injusto para el cliente y contractualmente problemático, cambia las reglas después de q' los vendedores ya vendieron y debería de avisarse con anticipación de su cambio.

6.- Un alumno copia el contenido de terminos_servicio.html dentro de politica_privacidad.html, argumentando q' ambos documentos legales son básicamente lo mismo. ¿Por qué esto es conceptualmente incorrecto al enfoque de la semana 3?

Son documentos con fines distintos. Los términos fijan las reglas de uso, compras y pagos; la política de privacidad explica por q' son los derechos q' tiene el usuario.

7.- motor-chatbot.js atiende consultas simulando ser un asistente de la tienda. Si la empresa no aclara en ningún momento q' se trata de un bot, ¿qué principio ético se está violando?

Se viola la honestidad, el cliente tiene derecho a saber si habla con un bot más explícitamente de que con quien se comunica es un asistente virtual.

8.- PrestaShop y Magento ofrecen soporte nativo multi-tienda/multi-idioma; WooCommerce requiere plugins adicionales para algo similar. Para una empresa q' planea vender en 3 países con catálogos e idiomas distintos ¿Qué implica elegir WooCommerce en ese escenario?

Implica plugins adicionales desde el inicio. Suma costo, mantenimiento, posibles incompatibilidades y dependencias de terceros. PrestaShop y Magento lo hacen de forma nativa.

9.- Magento Open Source es gratuito pero requiere desarrolladores especializados y más infraestructura; Adobe Commerce añade costo de licencia. ¿Cuál es el análisis correcto del costo total de propiedad (TCO), más allá del precio de la licencia?

TCO incluye más q' la licencia, hosting, plugins pagados, mantenimiento, seguridad, desarrolladores. Para una pyme sin desarrollador, WooCommerce suele tener menos costo, Magento Open S. es gratuito, pero exige especialistas e infraestructura potente.

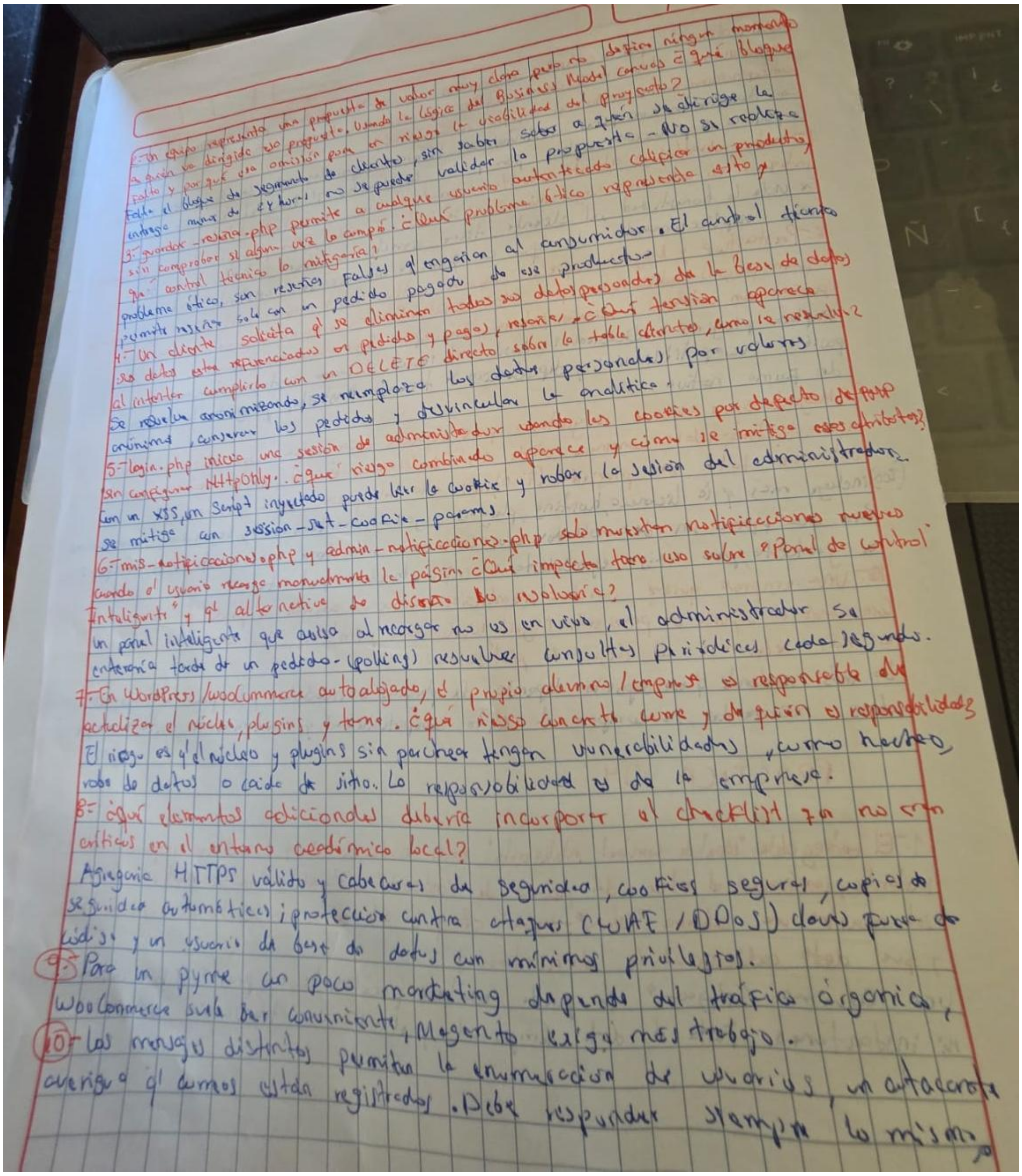
10.- Una empresa quiere vender membresías mensuales además de productos únicos. Comparando el soporte de pagos entre Magento, WooCommerce y PrestaShop, ¿qué consideración es más relevante al elegir la plataforma?

Lo más relevante q' ese soporte depende de plugins o módulos y la pasarela admita cobros recurrentes, se compara el costo, compatibilidad y mantenimiento antes de elegir.

## PRÁCTICA 04:

1.- El entregable "Panel de control inteligente" exige evidencia de q' el webhook respondió al instante, cambiando el estado del pedido de "Pendiente" a "Pagado" automáticamente. Un alumno solo muestra una columna "Estado: Pagado". ¿Por qué esto no es una evidencia suficiente, y qué dato adicional lo demostraría?

Una columna "Pagado" se puede editar fácilmente, no prueba q' fue automático ni instantáneo. Falta el dato temporal y el ID de transacción del pago.



1.- Un equipo representa una propuesta de valor muy clara pero no define ningún momento a quién va dirigida esa propuesta. Usando la lógica del Business Model Canvas ¿qué bloque falta y por qué esa omisión pone en riesgo la usabilidad del proyecto?

Falta el bloque de segmento de cliente, sin saber sobre a quién se dirige la
entrega mayor de 24 horas no se puede validar la propuesta. -NO se realiza

3.- guardar-reseña.php permite a cualquier usuario autenticado calificar un producto, sin comprobar si alguna vez lo compró. ¿Qué problema ético representa esto y qué control técnico lo mitigaría?

problema ético, son reseñas falsas q' engañan al consumidor. El control técnico permite reseñas solo con un pedido pagado de ese producto.

4.- Un cliente solicita q' se eliminen todos sus datos personales de la base de datos sus datos están referenciados en pedidos y pagos, reseñas, ¿Qué tensión aparece al intentar cumplirlo con un DELETE directo sobre la tabla clientes, cómo la resolvería?

Se resuelve anonimizando, se reemplaza los datos personales por valores anónimos, conservar los pedidos y desvincular la analítica.

5.- login.php inicia una sesión de administrador usando las cookies por defecto de PHP sin configurar HttpOnly. ¿qué riesgo combinado aparece y cómo se mitiga esos atributos?

Con un XSS, un script inyectado puede leer la cookie y robar la sesión del administrador. se mitiga con session_set_cookie_params.

6.- mis-notificaciones.php y admin-notificaciones.php solo muestran notificaciones nuevas cuando el usuario recarga manualmente la página ¿Qué impacto tiene eso sobre «Panel de control Inteligente» y qué alternativa de diseño lo resolvería?

Un panel inteligente que avisa al recargar no es en vivo, el administrador se enteraría tarde de un pedido. (polling) resolver consultas periódicas cada segundo.

7.- En WordPress/WooCommerce autoalojado, el propio alumno/empresa es responsable de actualizar el núcleo, plugins y temas. ¿Qué riesgo concreto corre y de quién es responsabilidad?

El riesgo es q' el núcleo y plugins sin parchear tengan vulnerabilidades, como hackeo, robo de datos o caída de sitio. La responsabilidad es de la empresa.

8.- ¿Qué elementos adicionales debería incorporar el checklist q' no eran críticos en el entorno académico local?

Agregaría HTTPS válido y cabeceras de seguridad, cookies seguras, copias de seguridad automáticas, protección contra ataques (WAF / DDoS) claves fuera de código y un usuario de base de datos con mínimos privilegios.

⑨.- Para una pyme con poco marketing depende del tráfico orgánico, WooCommerce suele ser conveniente, Magento exige más trabajo.

⑩.- Los mensajes distintos permiten la enumeración de usuarios, un atacante averigua q' correos están registrados. Debe responder siempre lo mismo.